DESIGN PROJECT – I · SEMESTER III · B.TECH, CYBER SECURITY

CryptoGuard

A Measured Password and File-Security Workbench

Malepati Sree Harsha · Register No. 23CU0340018
DISC · Hindustan Institute of Technology and Science, Chennai · 2024–25

THE PROBLEM

Strength meters hide the attacker's speed

- A meter says “centuries” — but at **how many guesses per second**?
- That speed depends mostly on the **server's storage scheme**, not the user
- Online checkers ask you to send secrets to a third party
- Goal: a **local** workbench that makes these trade-offs measurable

What CryptoGuard does

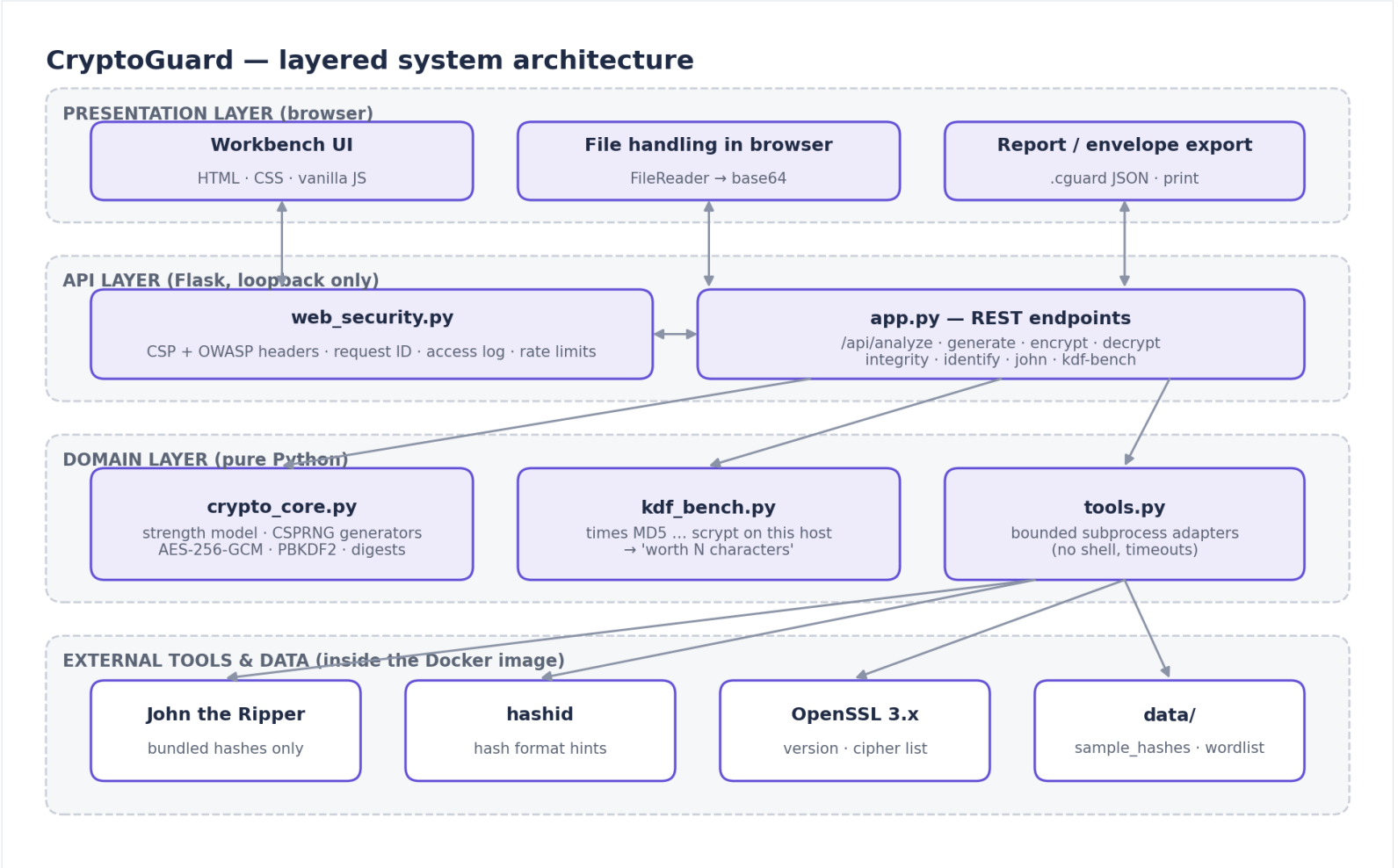
- Explainable password analysis with stated assumptions
- CSPRNG passwords and passphrases
- AES-256-GCM file encryption, PBKDF2 key derivation
- Integrity digests and hash identification
- Bounded John the Ripper demo on bundled hashes
- **Measured KDF benchmark** (novel component)

What exists, and what is missing

- Entropy scores mispredict real attacks (Weir 2010; Kelley 2012)
- zxcvbn models patterns, but still assumes one attacker speed
- NIST/OWASP give KDF parameters — as text only
- **Gap:** no learner tool measures storage cost in password-character units

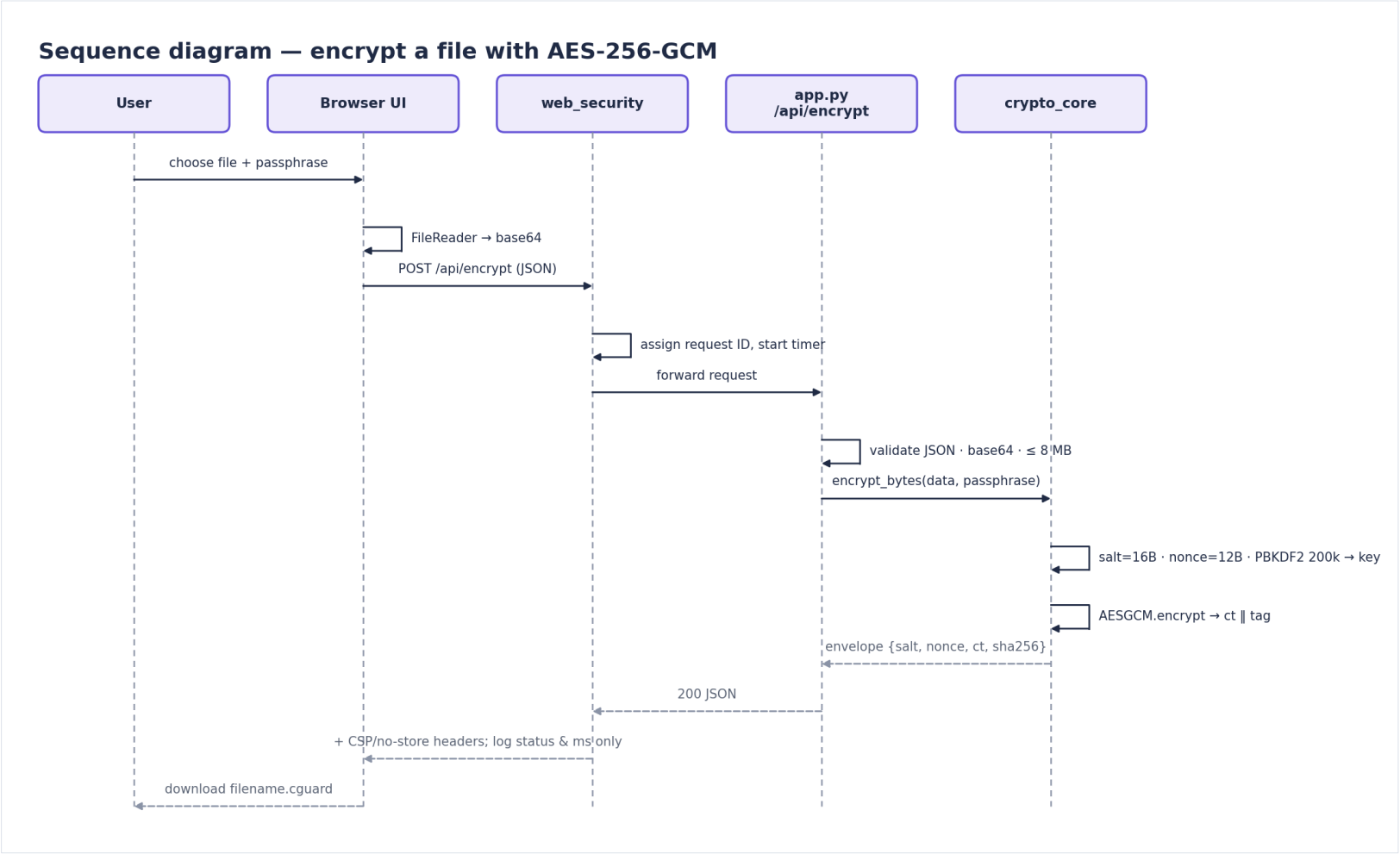
DESIGN

Layered architecture



KEY FLOW

Encrypting a file, end to end



NOVEL COMPONENT

Turning hash cost into password characters

- Time each scheme on the host for ~0.15 s
- Slowdown **k = rate(MD5) / rate(scheme)**
- One random character multiplies keyspace by **c**
- So the scheme is worth **log(k) / log(c)** characters
- The password only sets c and n — never hashed or logged

Built the way it teaches

- Strict CSP, anti-clickjacking, nosniff, no-referrer
- Request IDs; logs never contain bodies
- Rate limits on John and the benchmark (HTTP 429)
- Tools called without a shell, fixed paths, timeouts
- Non-root container, loopback-only port

RESULTS

Measured on the Docker image

3.5 M/s

MD5 guesses, one core

15.2/s

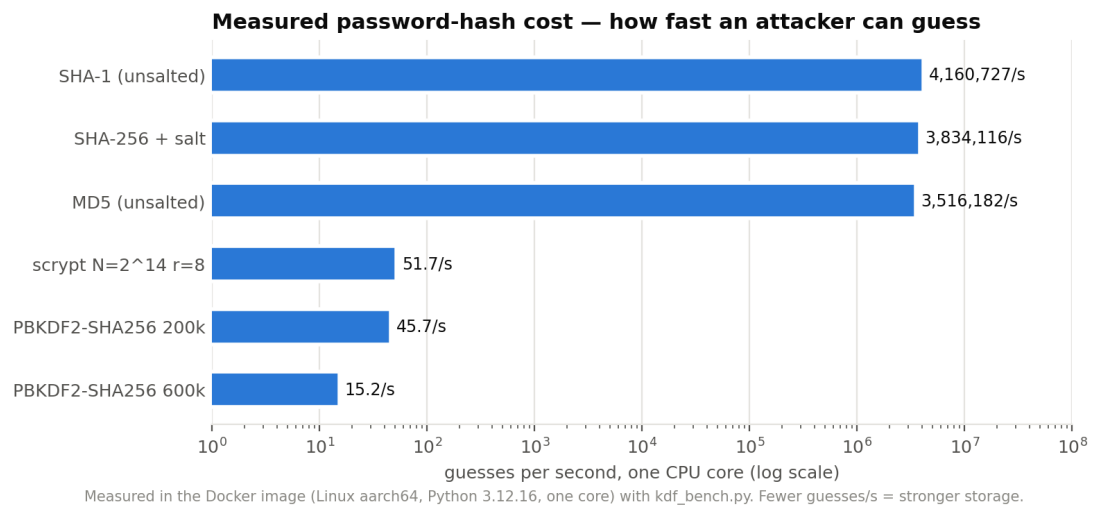
PBKDF2-600k guesses

231,328×

slowdown

+2.71

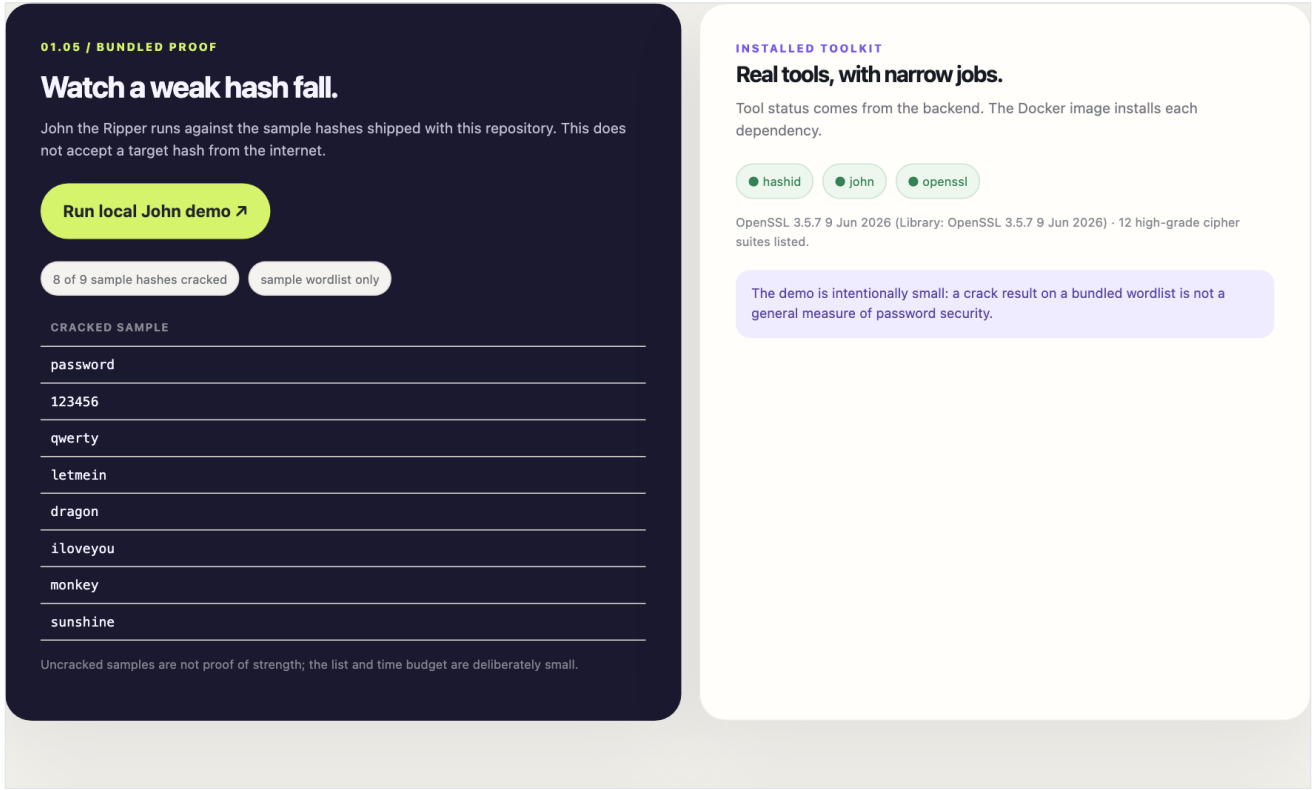
equivalent characters



RESULTS

It works — with real tools

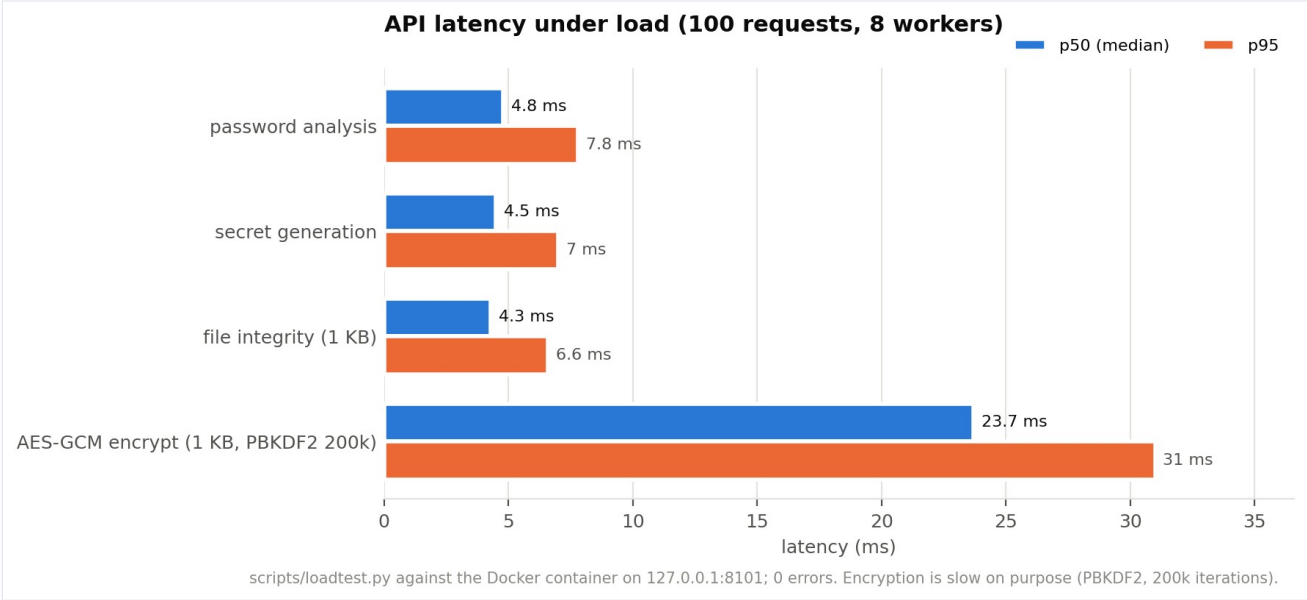
- John cracked **8/9** weak sample hashes
- GCM rejects wrong passphrase and tampering
- **14/14** automated tests pass
- p50 < 5 ms for non-KDF endpoints



TESTING

Unit, integration, security, performance

- 14 pytest cases incl. 5 security tests
- Playwright UI checks on the Docker build
- Load test: 0 errors across 400 requests



Limitations and future work

- Heuristic over-rates l33t dictionary words → add zxcvbn-style matching
- Single-core CPU benchmark misses GPU speed and scrypt's memory advantage
- Add bcrypt / Argon2id and a Hashcat GPU measurement
- Versioned envelope format with interoperability tests

CONCLUSION

Storage choices deserve the same visibility as password rules

- PBKDF2-600k vs MD5 ≈ **+2.7 random characters**, free for the user
- Local, private, hardened, tested and containerised
- Foundation for Design Projects II and III
- Thank you — questions?